
Vulnerability Assessment con Nmap e Nessus

Obiettivo: Eseguire scansioni di rete, identificare vulnerabilità e valutare i rischi utilizzando strumenti standard di settore come Nmap e Nessus.

Attività:

- Eseguire scansioni di rete con Nmap per identificare host attivi, porte aperte e servizi in esecuzione su metasploitable

Analisi dei Flag da me utilizzate

-A Aggressive Mode È una "combo". Attiva il rilevamento del sistema operativo

-O (OS **DetectionTenta**) di indovinare il sistema operativo analizzando come lo **stack** TCP/IP del target risponde ai pacchetti. (Nota: è già incluso in **-A**)

-Pn **No PingDice** a **Nmap** di non verificare se l'**host** è "vivo" tramite ICMP. Tratta il target come se fosse sempre online. Utile se c'è un firewall che blocca i ping.

-sU UDP Scan Scansiona le porte UDP. È molto più lenta della scansione TCP perché spesso non riceve risposta (stateless).

-sS TCP SYN Scan La scansione "**half-open**". Invia un pacchetto SYN; se riceve SYN/ACK, la porta è aperta, ma interrompe la connessione prima di completarla. È lo standard per velocità e furtività.

-sn Ping Scan Attenzione: Questo flag disabilita la scansione delle porte. Se lo hai usato insieme agli altri, potresti aver ricevuto solo la conferma che l'host è attivo, senza l'elenco delle porte.

-sV Version Detection Interroga le porte aperte per determinare esattamente quale software e quale versione stanno girando (es. Apache 2.4.41 invece di un generico "http").

Osservazioni Tecniche

1. Rumore e Visibilità: Questa combinazione è estremamente "rumorosa". Un sistema IDS (Intrusion Detection System) o un firewall moderno la rileverebbe istantaneamente a causa dell'intensità dei pacchetti e del tentativo di finger printing dell'OS.
2. Tempi di attesa: La scansione **-sU** (UDP) su un intero range di porte è notoriamente lenta. Se non hai specificato porte particolari (es. **-p 53,67,123**), Nmap potrebbe aver impiegato molto tempo per finire.

Se vuoi un report approfondito ma più pulito, potresti provare:

nmap -sS -sV -p- -T4 192.168.1.172

(Scansiona tutte le 65535 porte TCP, rileva le versioni e usa un timing aggressivo ma efficiente) senza cercare una per volta. IN ALLEGATO SCREEN DI KALI